# SBOM / CVE / Patch

**Çıktı: Vulnerability Decision**

Ad Soyad: _____ Grup: _____ Tarih: _____

**Kavram:** SBOM = yazılım malzeme listesi · CVE = açığın kayıt no'su · CVSS = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen var, sürüm etkileniyor, açık ulaşılabilir.

## Verilen zafiyet kaydı

| Alan | Değer |
|---|---|
| Bileşen | Component X (PLC firmware kütüphanesi) |
| Sürüm | 2.4 |
| CVE | CVE-XXXX-XXXX |
| Önem | Critical (CVSS 9.8) |
| Yama | Mevcut |

Karar: Üretimi durdurmadan, önce testle yamala; yama bitene kadar telafi edici önlem uygula.

## Görev — karar akışı

**1. Gerçekten etkiliyor mu? (üç şart)** Bileşen: Component X, WoodSander 5000 PLC firmware'inin SBOM'unda var mı? Sürüm: satıcı bildirimindeki etkilenen aralık 2.4'ü kapsıyor mu? Ulaşılabilirlik: zafiyetli servise hangi ağdan erişilebiliyor? PLC yalnızca Z2'de ve izinli conduit'lerden erişilebiliyorsa risk düşer; uzak erişimden doğrudan ulaşılıyorsa yüksektir. Üçü de evet ise CVE bizi etkiler.

**2. Üretimi hemen durdurur muyum?** Hayır. CVSS tek başına karar vermez; erişilebilirlik ve etki bağlamı önemlidir. Aktif istismar belirtisi varsa (anormal erişim, değişen konfigürasyon) üretim güvenli durumda durdurulur ve olay müdahalesi (LAB 6) başlar.

**3. Doğrudan mı, önce test mi?** Önce test. Aynı donanım/firmware'e sahip yedek PLC veya test tezgâhında (mümkünse simülasyon) denenir; canlı hatta doğrudan uygulanmaz. Yama planlı duruş penceresinde, geri dönüş planı ve konfigürasyon yedeğiyle uygulanır.

**4. Safety validation etkileniyor mu?** Yama safety fonksiyonunu çalıştıran PLC firmware'ine, safety kütüphanesine veya safety konfigürasyonuna dokunuyorsa evet. Anlama yolu: satıcı yama notları, değişiklik etki analizi, safety program imza/checksum karşılaştırması. Etkileniyorsa E-stop, kapı kilidi, ışık perdesi ve durma süresi testleri yeniden yapılır ve validation yeniden onaylanır.

**5. Yama mümkün değilse telafi edici önlemler:** Zafiyetli servis/portu kapatmak veya güvenlik duvarıyla yalnızca belirli makinelere açmak; uzak erişimi bakım penceresine kısıtlamak; PLC'yi Z2'de izole tutmak; anormal trafik ve konfigürasyon değişimi izleme; yedek ve geri dönüş planı; satıcıyla takip. Her önlem bitiş tarihi ve sorumluyla kayıt altına alınır.

*Bu föyün çıktısı Vulnerability Decision → Evidence Pack EP 09 · 10 · 11 başlığına oturur.*